

AI-Powered UK Trading Account Onboarding

Claude · MCP Servers · FCA Compliance · PostgreSQL · Next.js

6

MCP Servers

5

Products

3

Databases

100%

Deterministic Rules

The Problem with Traditional Onboarding

Slow & Manual

Weeks of paper forms, wet signatures, and manual KYC checks. Customers drop off before completion.

Compliance Risk

FCA rules (COBS 10.2, COBS 19) require precise journey steps per product. One mistake = regulatory exposure.

PII Scattered

Personal data stored in flat files or CRMs with no field-level encryption or access audit trail.

No Intelligence

Static forms can't adapt. Wrong questions asked, right ones missed. No memory across sessions.

The Solution

Claude acts as an intelligent orchestrator. All compliance decisions stay in deterministic MCP servers — never in the LLM.

Claude orchestrates. MCP servers decide. Audit trail proves it.



Claude Orchestrator

Guides the customer conversationally. Decides which MCP tool to call next. Never makes PASS/FAIL decisions.



6 MCP Servers

Personal Details, KYC, Suitability, Eligibility, Disclosure, Audit. Each owns its rules and data store.



JSON Rules Engine

All FCA rules encoded in version-controlled JSON. Product journey steps, field requirements, scoring thresholds.



3 Domain Databases

Sessions, Audit events, and PII each in isolated PostgreSQL databases. AES-256-GCM field encryption for PII.

Three-Step Onboarding Flow

01

Product Selection

- ISA — Stocks & Shares
- GIA — General Investment
- CFD — Contracts for Diff.
- SIPP — Personal Pension
- OPTIONS — Derivatives

Journey steps auto-determined
by eligibility rules JSON

02

Personal Details Form

- Full name + date of birth
- NI number + UK address
- Employment & income
- PEP / FATCA declarations
- Conditional fields by product

AES-256-GCM encrypted
per-field in onboarding_pii

03

AI-Guided Journey

- KYC verification
- Appropriateness test (if req.)
- FCA disclosure text
- Risk warnings verbatim
- Account provisioning

Claude + MCP tools
Full audit trail in PostgreSQL

5 FCA-Regulated Products

Each product has its own compliance journey, rules version, and disclosure requirements.

ISA	Stocks & Shares ISA No test	PD → KYC → Disclosure → Account
GIA	General Investment Account No test	PD → KYC → Disclosure → Account
CFD	Contracts for Difference Appropriateness test	COBS 10.2 · 1:30 leverage · 70% loss warning PD → KYC → Suitability → Disclosure → Risk Warning → Account
SIPP	Self-Invested Personal Pension Declaration required	COBS 19 PD → KYC → Suitability → Disclosure → Pension Decl → Account
OPTIONS	Options & Derivatives Appropriateness test	COBS 10.2 · Score ≥ 4/6 PD → KYC → Suitability → Disclosure → Risk Warning → Account

Personal Details Form

Full legal name

e.g. John Smith

Date of birth

YYYY-MM-DD

Nationality

United Kingdom

National Insurance number

e.g. AB 12 34 56 C

Address

123 High Street, London, SW1A 1AA

Employment status

Select...

⚡ Conditional fields auto-shown by product: Income band & Source of wealth (CFD/SIPP/OPTIONS) · Tax residency (SIPP/GIA)

FCA Compliance Built-in



AES-256-GCM

Field-level encryption per customer. 12-byte random IV per field. Key never logged.



NI Validation

UK NI regex enforced client-side and server-side before save.



Postcode Check

UK postcode format validated. Invalid formats blocked.



PEP / FATCA

Explicit declaration checkboxes. PEP flag written to immutable audit trail.



Age ≥ 18

Date of birth validated server-side. Under-18s blocked at save.

System Architecture

FRONTEND • Next.js 14 • Chat UI + Audit Panel • Product Selector • Personal Details Form

REST proxy  /api/chat

CLAUDE ORCHESTRATOR • Express • Agentic Loop • $O(1)$ Map<toolName,Client> dispatch • appendAndSave sessions

 stdio subprocesses

PII
Server

KYC
Server

Suitability
Server

Eligibility
Server

Disclosure
Server

Audit
Server



JSON Rules Engine
rules/uk/*.json — eligibility • kyc • suitability • disclosures



PostgreSQL • 3 Databases
onboarding_sessions • onboarding_audit • onboarding_pii

Compliance & Audit Trail

✗ What Claude NEVER Does

- Make a PASS / FAIL compliance decision
- Generate disclosure or risk warning text
- Reorder FCA-mandated journey steps
- Override an appropriateness test FAIL
- Store or log the PII encryption key

✓ Every Event Audited

- PERSONAL_DETAILS_COMPLETED
- KYC_COMPLETED · SANCTIONS_CHECKED
- SUITABILITY_COMPLETED (score + threshold)
- PEP_FLAGGED · FATCA_FLAGGED
- DISCLOSURE_PRESENTED (text hash)

```
{ "event_type": "SUITABILITY_COMPLETED", "decision": "FAIL", "tool_name": "run_appropriateness_test",  
  "input_snapshot": { "product_code": "CFD", "answers": { "q1": "none" } },  
  "output_snapshot": { "score": 3, "pass_threshold": 6 }, "rule_version": "1.0.0" }
```


Demo: ISA vs CFD Journey Comparison

ISA — Simple Path

- 1 Select ISA
- 2 Fill personal details form
- 3 KYC: identity + sanctions
- 4 Receive ISA disclosure text
- 5 Account created ✓

No appropriateness test required.
Typical: 5-7 minutes.

CFD — Full Compliance Path

- 1 Select CFD
- 2 Fill personal details + income + source of wealth
- 3 KYC: identity + sanctions + vulnerability check
- 4 Appropriateness test: 4 questions, score $\geq 6/12$
- 4F **FAIL → 30-day retest enforced (Claude cannot override)**
- 5 FCA disclosure: COBS 10.2 + 70% loss warning
- 6 Account created ✓

COBS 10.2 · 1:30 leverage limit.
FAIL path terminates journey.

Technology Stack

AI & Protocol

Claude Sonnet 4.6

Anthropic LLM orchestrator. Agentic loop with tool use.

MCP SDK

Model Context Protocol — stdio transport, JSON-RPC 2.0.

Shared Factory

`createMcpServer()` — one pattern for all 6 servers.

Frontend

Next.js 14

App Router. /api proxy routes. 3-step onboarding flow.

React 18

Client components. `useRef` for scroll, `useEffect` for auto-send.

Tailwind CSS 3

Utility-first. Conditional field rendering. Responsive layout.

Backend

Express 4

Orchestrator HTTP server. /chat, /audit/:id, /sessions.

TypeScript 5

Strict mode. Zod schemas for all MCP tool inputs.

PostgreSQL 16

3 isolated databases. JSONB messages. pg pool per server.

Security

AES-256-GCM

Field-level PII encryption. 12-byte IV. Auth tag verified on read.

Lazy key init

Encryption key resolved at first use, not at module import.

Domain isolation

Sessions, Audit, PII in separate DBs. Separate connection pools.

Key Differentiators

LLM orchestrates, rules decide

Claude never makes compliance calls. Every PASS/FAIL comes from deterministic JSON rules. Provable in the audit trail.

Immutable audit trail

Every tool call writes an event to PostgreSQL. Session ID, customer ID, decision, input snapshot, output snapshot, rule version.

Field-level encryption

AES-256-GCM with per-field random IV. PII database is isolated. Key loaded lazily from env, never logged.

O(1) tool dispatch

Map<toolName, Client> built at startup. Zero fan-out, zero try/catch probing. Parallel tool calls via Promise.all.

Rules-as-config

Add a new product or region by adding a JSON file. No MCP server code changes required. Rules path is env-configurable.

Docker-first

3 domain databases provisioned by init script. Orchestrator and frontend in the same compose file. One command to run.